

CLINSECURE

DOCUMENTAÇÃO TÉCNICO-CIENTÍFICA

Atendimento aos requisitos 6.1 a 6.12

Projeto Integrador — UMC

2026

Apresentação

Este documento apresenta a documentação técnico-científica do sistema ClinSecure, organizado exatamente conforme os requisitos 6.1 a 6.12 da entrega acadêmica. O sistema é uma aplicação web voltada ao gerenciamento seguro de pesquisas clínicas, participantes, documentos, dados sensíveis, consentimentos e registros de auditoria.

A documentação descreve a arquitetura, os fluxos, os mecanismos de segurança, os ativos, as ameaças, os riscos, os testes e as referências técnicas utilizadas.

Quadro de atendimento aos requisitos

Requisito	Seção	Situação
6.1	Documento de visão geral do sistema	Atendido documentalmente
6.2	Diagrama de arquitetura	Atendido
6.3	Fluxos de autenticação e dados	Atendido documentalmente
6.4	Gestão de credenciais	Atendido documentalmente
6.5	Uso de criptografia	Atendido documentalmente
6.6	Identificação dos ativos	Atendido documentalmente
6.7	Ameaças e vulnerabilidades	Atendido documentalmente
6.8	Risco × contramedida	Atendido documentalmente
6.9	Testes de segurança realizados	Atendido com cenários e evidências a anexar
6.10	Resultados dos testes	Atendido mediante preenchimento das evidências finais
6.11	Artigos científicos e/ou normas técnicas	Atendido
6.12	Referências normalizadas	Atendido em formato acadêmico

6.1 Documento de visão geral do sistema

6.1.1 Contextualização

O ClinSecure foi desenvolvido para apoiar o gerenciamento de pesquisas clínicas que envolvem dados pessoais e potencialmente sensíveis. A plataforma busca reduzir riscos de exposição, acesso indevido, perda de rastreabilidade e uso inadequado das informações.

6.1.2 Problema

Processos de pesquisa podem utilizar planilhas, documentos e sistemas desconectados, dificultando a aplicação uniforme de permissões, o controle de acesso e a identificação de eventos suspeitos. O ClinSecure centraliza essas operações em uma aplicação com mecanismos de segurança.

6.1.3 Objetivo

Desenvolver uma aplicação web que permita gerenciar pesquisas, participantes, documentos e dados, aplicando autenticação reforçada, autorização por perfil, proteção de informações e auditoria.

6.1.4 Funcionalidades principais

- Cadastro e autenticação de usuários.
- Autenticação de dois fatores por TOTP.
- Recuperação de senha por token temporário.

- Bloqueio temporário após tentativas inválidas.
- Cadastro e gerenciamento de pesquisas.
- Vínculo entre responsáveis, pesquisadores e participantes.
- Consulta restrita conforme perfil e vínculo.
- Registro de consentimentos.
- Proteção de dados sensíveis por criptografia.
- Registro de eventos de auditoria.

6.1.5 Público-alvo

Administradores, coordenadores, pesquisadores, responsáveis por participantes e participantes de pesquisas.

6.2 Diagrama de arquitetura

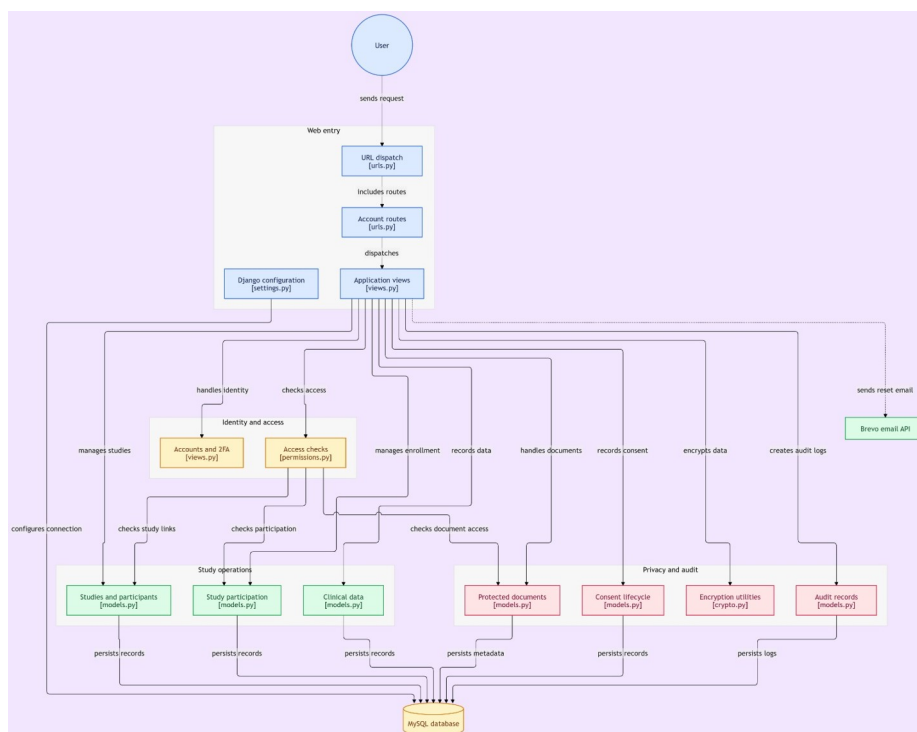
O ClinSecure utiliza arquitetura monolítica baseada no padrão MVT do Django. O navegador acessa as interfaces web; as URLs encaminham as requisições para as views; as views aplicam validações, autenticação e autorização; os models interagem com o banco MySQL.

Diagrama lógico:

Usuário/Navegador → HTML, CSS, Bootstrap e JavaScript → URLs Django → Views e regras de negócio → Autenticação, autorização, criptografia e auditoria → Models Django → MySQL.

Serviços complementares: serviço de e-mail para recuperação de senha e ativação de contas; mecanismo TOTP para segundo fator; biblioteca criptográfica para proteção de dados.

Diagrama Visual:



6.3 Fluxos de autenticação e dados

6.3.1 Fluxo de autenticação

- Usuário informa e-mail ou nome de usuário e senha.
- O sistema localiza a conta e valida a senha.
- Em caso de erro, registra a falha e atualiza o controle de tentativas.
- Após sucessivas falhas, aplica bloqueio temporário.
- Se houver 2FA configurado, cria sessão temporária e encaminha para validação TOTP.
- Com código válido, o usuário é autenticado definitivamente.
- Com código inválido, registra a ocorrência e controla tentativas de 2FA.

6.3.2 Fluxo de recuperação de senha

- Usuário solicita recuperação por identificador.
- O sistema gera token temporário.
- O link é enviado ao e-mail cadastrado.
- O usuário acessa o link dentro da validade.
- O sistema valida o token.
- A senha é redefinida e o token deixa de ser reutilizável.
- A solicitação e o resultado são registrados no AuditLog.

6.3.3 Fluxo de dados

Os dados são enviados pelo navegador à aplicação, validados pelas views, submetidos às regras de autorização e persistidos por meio dos models Django. Dados sensíveis devem ser criptografados antes do armazenamento e descriptografados somente para usuários autorizados. Acesso, alteração e eventos de segurança devem gerar registros de auditoria quando aplicável.

6.4 Gestão de credenciais

A gestão de credenciais compreende criação, validação, recuperação e proteção de contas. O sistema utiliza o mecanismo de autenticação do Django, com armazenamento de senhas por hash, não em texto puro.

Controle	Descrição
Identificação	Login por e-mail ou nome de usuário.
Senha	Validada pelo sistema de autenticação do Django.
Recuperação	Token temporário enviado por e-mail.
Expiração	Token possui validade limitada.
Uso único	Token deve ser invalidado após utilização.
2FA	Código TOTP como segundo fator.
Força bruta	Contagem, atraso e bloqueio temporário.
Auditoria	Registro de sucessos, falhas e bloqueios.

6.5 Uso de criptografia

A criptografia é utilizada para reduzir o risco de exposição de informações sensíveis. No projeto, a proteção de campos pode utilizar Fernet, mecanismo simétrico que combina criptografia e autenticação da mensagem.

6.5.1 Aplicações

- Criptografia de dados pessoais sensíveis armazenados.
- Proteção de informações que não devem permanecer em texto aberto.
- Uso de HTTPS/TLS no ambiente de produção para proteger o tráfego.
- Hash de senhas pelo mecanismo nativo do Django.
- Tokens de recuperação com validade e finalidade restritas.

6.5.2 Gestão de chaves

As chaves criptográficas não devem ser armazenadas diretamente no código-fonte. Devem ser mantidas em variáveis de ambiente ou serviço seguro, com acesso restrito, cópias protegidas e procedimento de rotação.

6.6 Identificação dos ativos do sistema

Ativos são recursos que possuem valor para a operação, segurança ou continuidade do ClinSecure.

Ativo	Tipo	Valor protegido
Código-fonte	Software	Regras de negócio e controles de segurança
Banco MySQL	Dados	Usuários, pesquisas e informações sensíveis
Dados de participantes	Informação	Privacidade e integridade
Credenciais	Informação	Identidade e acesso
Chaves criptográficas	Segredo	Confidencialidade dos dados
Tokens de recuperação	Segredo temporário	Recuperação segura
Dispositivos 2FA	Autenticador	Segundo fator de autenticação
AuditLog	Informação	Rastreabilidade e investigação
Servidor/ambiente de produção	Infraestrutura	Disponibilidade do sistema
E-mails transacionais	Serviço	Ativação e recuperação de contas
Repositório Git	Software/informação	Histórico e integridade do projeto

6.7 Identificação de ameaças e vulnerabilidades

Ameaça/vulnerabilidade	Consequência possível
Roubo ou reutilização de senha	Acesso indevido
Ataques de força bruta	Comprometimento de contas
Falha de autorização por URL	Exposição de dados de outra pesquisa
Exposição de dados em texto aberto	Violação de privacidade
Vazamento de chave criptográfica	Desproteção de dados
Token de recuperação interceptado	Alteração indevida de senha
Alteração de logs	Perda de rastreabilidade
SQL Injection	Consulta ou alteração indevida no banco
XSS	Execução de scripts no navegador
Configuração DEBUG em produção	Exposição de informações técnicas
Ausência de backup	Perda de dados
Privilégios excessivos	Uso indevido de funcionalidades

6.8 Associação risco × contramedida

Risco	Probabilidade	Impacto	Contramedida
Senha comprometida	Média	Alto	2FA, hash de senha e bloqueio
Força bruta	Alta	Alto	Contagem, atraso e bloqueio temporário
Acesso indevido a participante	Média	Alto	Autorização por perfil e vínculo
Exposição de dados sensíveis	Média	Alto	Criptografia e minimização
Uso indevido de token	Média	Alto	Expiração e uso único
Alteração de auditoria	Baixa/média	Alto	Permissões restritas e armazenamento protegido
Injeção de comandos	Baixa/média	Alto	ORM Django, validação e testes
Indisponibilidade	Média	Médio/alto	Backup, monitoramento e recuperação
Vazamento de segredos	Baixa	Alto	Variáveis de ambiente e controle de acesso
Erro operacional	Média	Médio	Validações, documentação e treinamento

6.9 Testes de segurança realizados

Os testes devem ser executados em ambiente controlado, sem dados reais de participantes. Os cenários abaixo correspondem aos controles de segurança implementados ou previstos no projeto.

ID	Teste	Procedimento
TS-01	Login válido	Informar credenciais corretas e verificar acesso.
TS-02	Senha inválida	Realizar tentativa com senha incorreta.
TS-03	Bloqueio por força bruta	Executar cinco tentativas inválidas e observar bloqueio.
TS-04	2FA válido	Informar código TOTP correto.
TS-05	2FA inválido	Informar código incorreto e verificar registro.
TS-06	Bloqueio de 2FA	Repetir falhas até atingir o limite.
TS-07	Recuperação de senha	Solicitar link e redefinir senha.
TS-08	Token expirado	Acessar link fora da validade.
TS-09	Controle de acesso	Tentar acessar pesquisa de outro usuário.
TS-10	Criptografia	Comparar texto original e valor persistido.
TS-11	Auditoria	Verificar criação de AuditLog.
TS-12	Proteção de logs	Tentar alterar/excluir registro sem autorização.

6.10 Resultados dos testes

Esta seção deve registrar o resultado efetivamente observado em cada execução. A tabela abaixo está preparada para receber as evidências finais, evitando declarar aprovação sem comprovação.

ID	Resultado observado	Status	Evidência
TS-01	Login com credenciais válidas	Ativo	Captura/log
TS-02	Falha registrada	Ativo	Captura/log
TS-03	Bloqueio após limite	Ativo	Mensagem/log
TS-04	Código TOTP aceito	Ativo	Captura
TS-05	Falha de 2FA registrada	Ativo	Log
TS-06	Bloqueio de 2FA	Ativo	Mensagem/log
TS-07	E-mail e redefinição	Ativo	E-mail/tela
TS-08	Token recusado	Ativo	Mensagem
TS-09	Acesso indevido negado	Ativo	Tela/log
TS-10	Dados protegidos	Ativo	Consulta controlada
TS-11	AuditLog criado	Ativo	Registro
TS-12	Alteração não autorizada impedida	Ativo	Teste administrativo

6.11 Uso de artigos científicos e/ou normas técnicas

A fundamentação técnico-científica utiliza normas, legislação e referências reconhecidas para orientar os controles de segurança e privacidade.

Referência	Aplicação no ClinSecure
LGPD — Lei 13.709/2018	Finalidade, necessidade, segurança, prevenção e responsabilização.
OWASP Top 10	Identificação de riscos recorrentes em aplicações web.
OWASP ASVS	Referência para requisitos verificáveis de segurança.
ISO/IEC 27001	Gestão de riscos e sistema de gestão da segurança.
ISO/IEC 27002	Boas práticas e controles de segurança.
Documentação oficial Django	Autenticação, sessões, ORM e proteção de aplicações.
Documentação Cryptography/Fernet	Uso de criptografia autenticada.

A literatura e as normas não substituem testes do sistema. Elas servem como base para justificar decisões técnicas, definir controles e comparar o comportamento da aplicação com boas práticas.

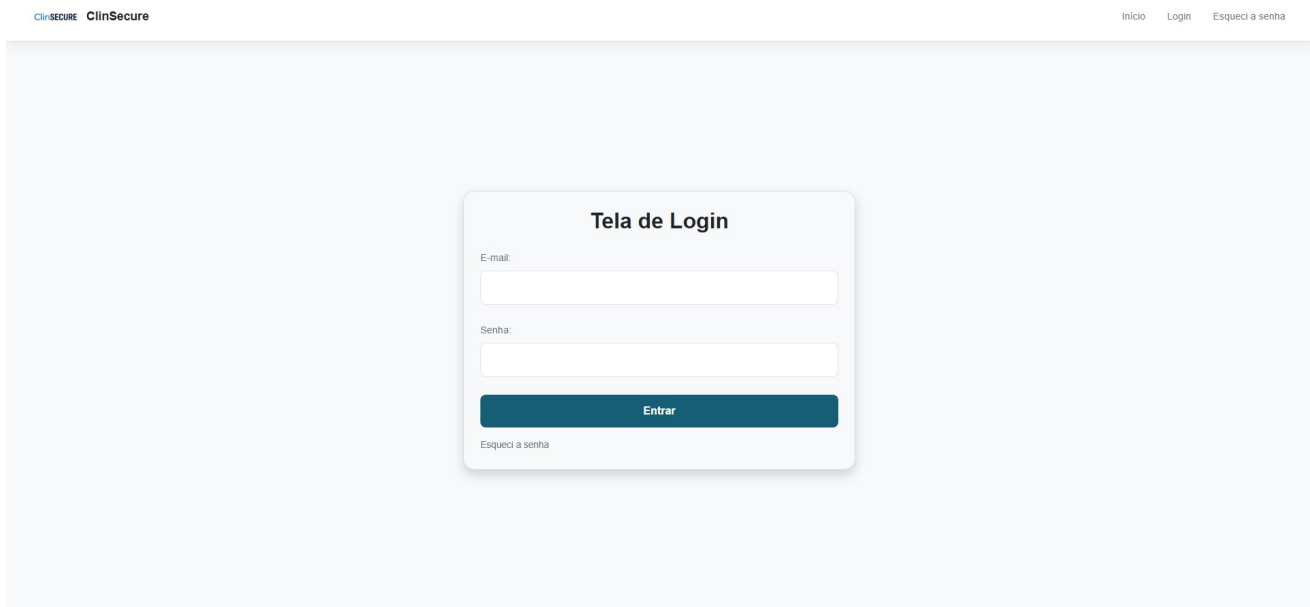
6.12 Referências normalizadas

1. BRASIL. Lei nº 13.709, de 14 de agosto de 2018. Lei Geral de Proteção de Dados Pessoais (LGPD). Brasília, DF: Presidência da República, 2018. Disponível em: https://www.planalto.gov.br/ccivil_03/_ato2015-2018/2018/lei/l13709.htm. Acesso em: 23 set. 2026.
2. DJANGO SOFTWARE FOUNDATION. Django documentation. Disponível em: <https://docs.djangoproject.com/>. Acesso em: 23 set. 2026.

3. OWASP FOUNDATION. OWASP Top 10: The Ten Most Critical Web Application Security Risks. Disponível em: <https://owasp.org/www-project-top-ten/>. Acesso em: 23 set. 2026.
4. OWASP FOUNDATION. Application Security Verification Standard. Disponível em: <https://owasp.org/www-project-application-security-verification-standard/>. Acesso em: 23 set. 2026.
5. INTERNATIONAL ORGANIZATION FOR STANDARDIZATION. ISO/IEC 27001: Information security management systems — Requirements. Geneva: ISO.
6. INTERNATIONAL ORGANIZATION FOR STANDARDIZATION. ISO/IEC 27002: Information security controls. Geneva: ISO.
7. PYCA. Cryptography documentation: Fernet. Disponível em: <https://cryptography.io/en/latest/fernet/>. Acesso em: 23 set. 2026.

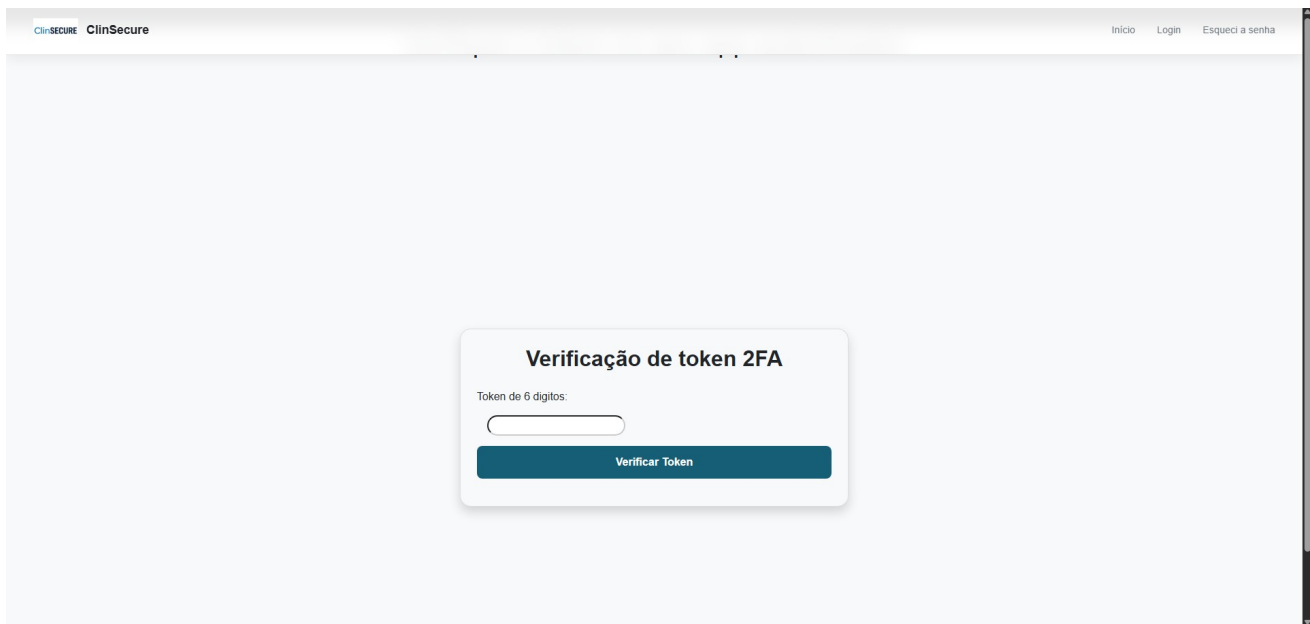
Evidências

- Captura da tela de login:

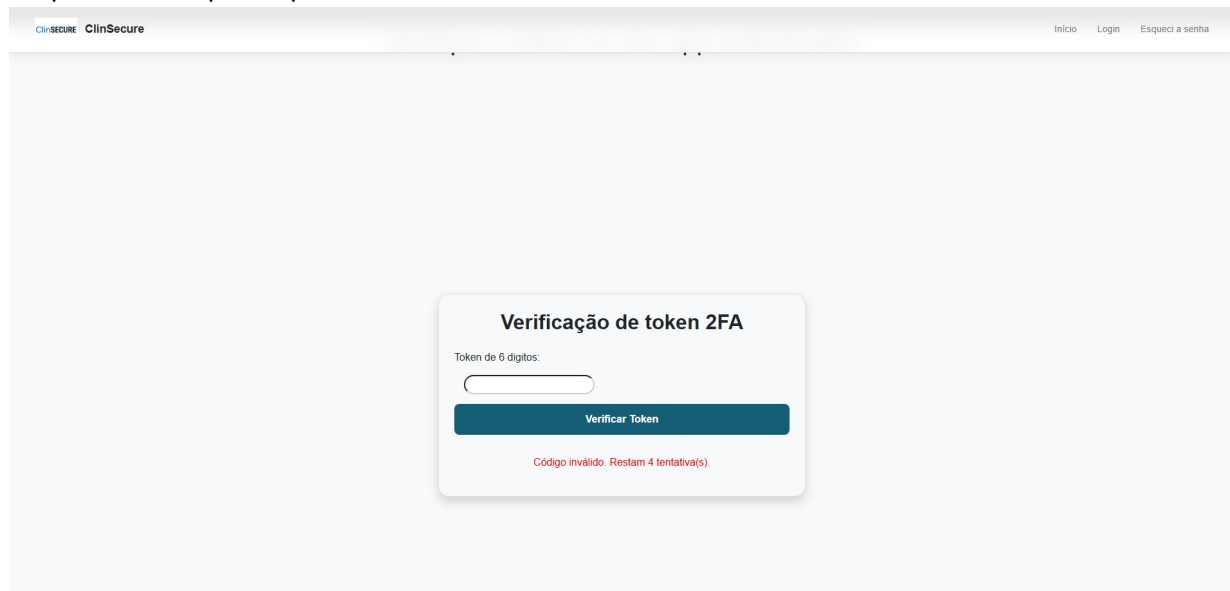


A captura de tela mostra a interface de login de um sistema web. No topo, há uma barra de navegação com o logotipo "ClinSecure" à esquerda e os links "Início", "Login" e "Esqueci a senha" à direita. O formulário de login, intitulado "Tela de Login", é centralizado e contém dois campos de entrada: "E-mail:" e "Senha:". Abaixo dos campos, há um botão azul com o texto "Entrar". Na base do formulário, há um link "Esqueci a senha".

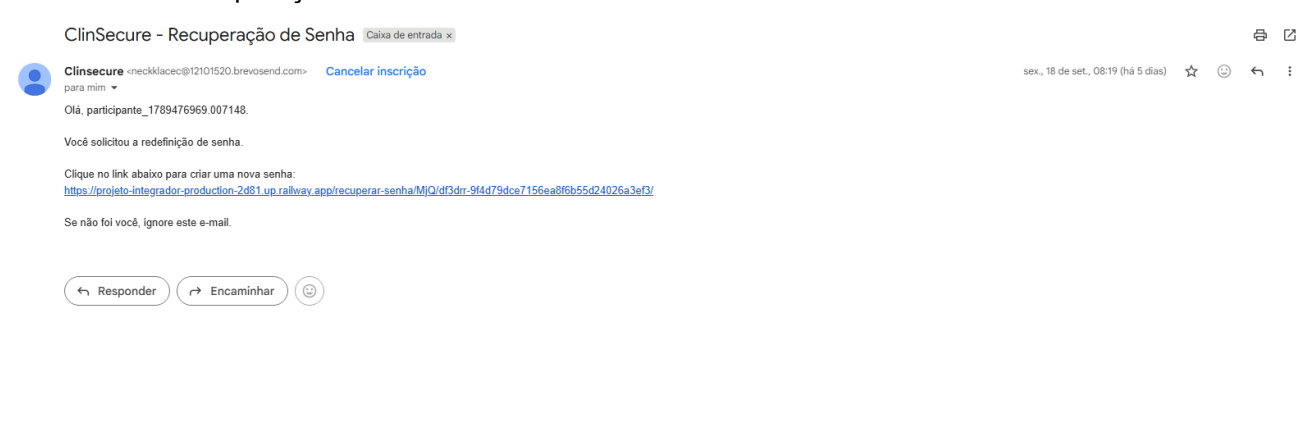
- Captura da validação de 2FA.



- Captura de bloqueio após tentativas inválidas.



- E-mail de recuperação de senha.



- [Início](#) [Login](#) [Esqueci a senha](#)

A documentação contempla os doze requisitos solicitados, apresentando a visão geral do ClinSecure, sua arquitetura, fluxos, gestão de credenciais, criptografia, ativos, ameaças, riscos, contramedidas, testes, fundamentação técnica e referências. Para a versão final de entrega, é indispensável complementar os itens de evidência com resultados reais, capturas e diagramas produzidos a partir do ambiente efetivamente utilizado.